

Threat Analysis Report

รายงานวิเคราะห์ ชุดเครื่องมือ WebShell
x.php ของกลุ่ม NXBBSEC

15/11/2025

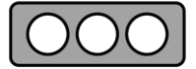
TLP:CLEAR





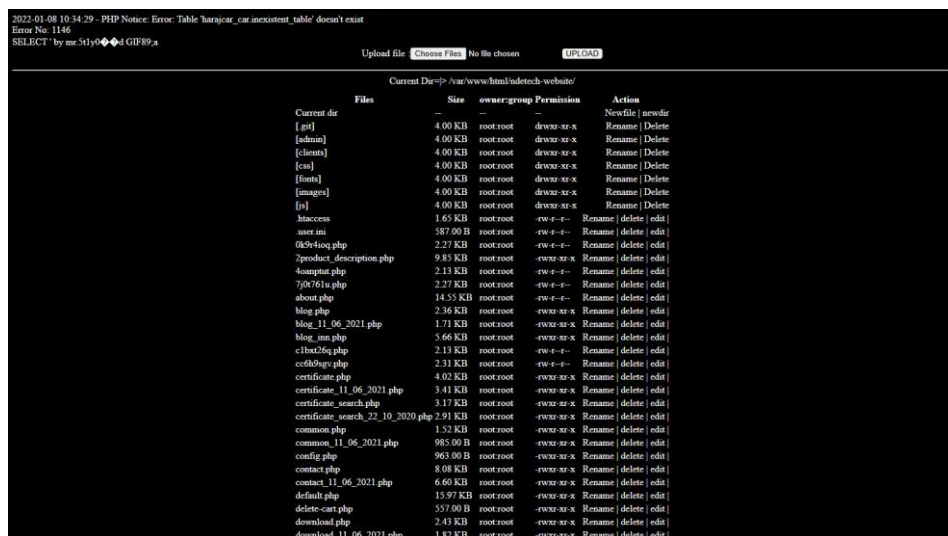
สารบัญ

สารบัญ.....	2
บทสรุปสำหรับผู้บริหาร.....	3
การวิเคราะห์เชิงเทคนิค.....	3
Technique Tactics and Procedures (MITRE ATT&CK).....	6
Indicator of Compromise (IOCs).....	7
แนวทางการเฝ้าระวัง ป้องกัน และรับมือ.....	8

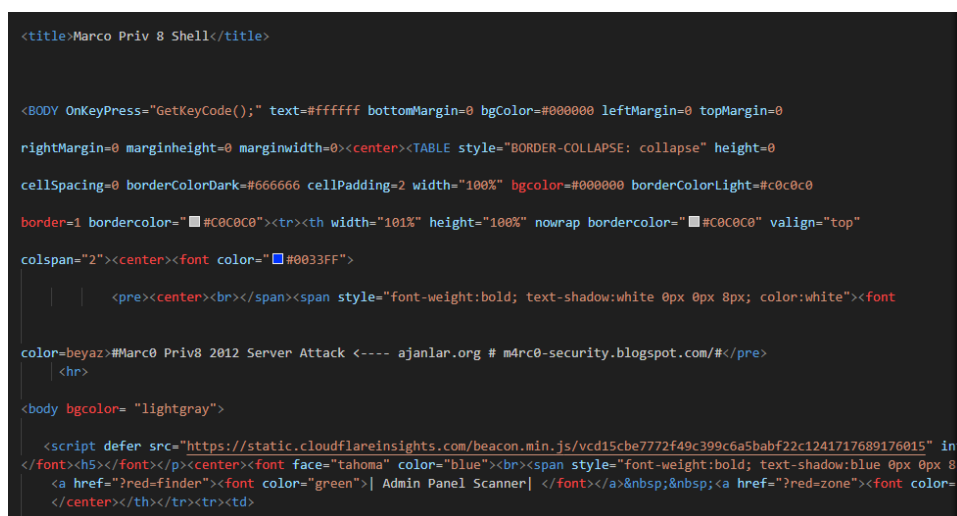


บทสรุปสำหรับผู้บริหาร

เมื่อวันที่ 15 พฤศจิกายน 2568 กลุ่ม NXBBSEC เผยแพร่เครื่องมือ WebShell ที่ถูกฝังบนเว็บไซต์ [hxxps://ndetech.org.in/x\[.\]php](https://ndetech.org.in/x[.]php) ตั้งชื่อไฟล์ว่า x.php จากการตรวจสอบพบเทคนิคการหลบเลี่ยง (Defense Evasion) โดยการปลอมแปลงส่วนหัวไฟล์เป็นรูปภาพ (GIF89a) เพื่อหลอกระบบความปลอดภัย และพบร่องรอยการสร้างไฟล์ Backdoor แบบสุ่มชื่อ (Randomized Filenames) จำนวนมากกระจายอยู่ในระบบ ซึ่งบ่งชี้ว่าเซิร์ฟเวอร์ถูกยึดครองและอาจถูกเปลี่ยนเป็นฐานสำหรับการโจมตี Botnet หรือใช้เพื่อวัตถุประสงค์ในการฝังโฆษณาพนัน/สแปม



(ภาพเว็บไซต์ที่ถูกฝัง webshell)



(ภาพโค้ดจาก x.php)



การวิเคราะห์เชิงเทคนิค

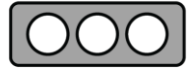
1. Webshell (index.html)

กลไกการทำงาน:

- **เทคนิคการหลบเลี่ยง (Defense Evasion: GIF89a Spoofing)** : แสกเกอร์ใส่ Header มาตรฐานของไฟล์รูปภาพ GIF (GIF89a) ไว้ที่ส่วนหัวของไฟล์สคริปต์ วิธีนี้ใช้เพื่อหลบเลี่ยงการตรวจสอบของ WAF หรือฟังก์ชันตรวจสอบชนิดไฟล์ (MIME Type Check) ของเซิร์ฟเวอร์ ทำให้ระบบเข้าใจผิดว่าเป็นไฟล์รูปภาพ แต่เมื่อ PHP Interpreter ทำงาน ไฟล์สคริปต์ดังกล่าวจะข้ามส่วน Header นี้และรันโค้ดต่อทันที
- **File Management:** สามารถ อัปโหลด (Upload), สร้างไฟล์/โฟลเดอร์ใหม่, เปลี่ยนชื่อ, ลบ, และแก้ไขไฟล์ได้
 - การอัปโหลดไฟล์ (File Upload) พบ <form> ที่ใช้


```
enctype="multipart/form-data" และ action a=upload
<form method="post" class="in" enctype="multipart/form-data"
action="?d=/var/www/html/ndetech-website&a=upload">
<center>Upload file :
<input type="file" name="fileup[]" multiple="" style="border:
0">
<input type="submit" name="upload" value="UPLOAD">
</form>
```
 - สร้างไฟล์และโฟลเดอร์ใหม่ (Create New File/Directory) พบลิงก์ที่ส่ง


```
Parameter a=touch (สร้างไฟล์) และ a=mkdir (สร้างโฟลเดอร์)
<td align=right>
<a href='?d=/var/www/html/ndetech-
website&a=touch'>Newfile</a> |
```



```
<a href='?d=/var/www/html/ndetech-website&a=mkdir'>newdir</a>
```

```
</td>
```

- เปลี่ยนชื่อและลบไฟล์ (Rename & Delete) พบลิงก์ Action a=rename และ a=delete ในแต่ละแถวของตารางไฟล์

```
<td align="right">
```

```
<a href="?d=/var/www/html/ndetech-website/.git&a=rename">Rename</a> |
```

```
<a href="?d=/var/www/html/ndetech-website/.git&a=delete">Delete</a>
```

```
</td>
```

- แก้ไขไฟล์ (Edit File) พบลิงก์ Action a=edit ซึ่งจะเปิดหน้าต่างสำหรับแก้ไข Source Code ของไฟล์นั้นๆ

```
<td align="right">
```

```
...
```

```
<a href="?d=/var/www/html/ndetech-website&a=edit&f=.htaccess">edit</a> |
```

```
</td>
```

- **Mass Infection Indicators:** จากการตรวจสอบรายชื่อไฟล์ในตาราง พบไฟล์ PHP ที่มีชื่อเป็นตัวอักษรและตัวเลขสุ่มความยาว 8 ตัวอักษร จำนวนมาก ได้แก่:

- 0k9r4ioq.php
- 4oanptut.php
- 7j0t761u.php
- c1bxt26q.php

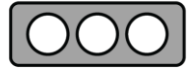
และอื่นๆ อีกกว่า 10 ไฟล์ วิเคราะห์: นี่เป็นพฤติกรรมของ AutomatedMalware/Dropper ที่พยายามสร้าง Backdoor สำรองไว้หลายจุด



Technique Tactics and Procedures (MITRE ATT&CK)

MITRE ATT&CK คือฐานความรู้ที่รวบรวมและจัดหมวดหมู่กลยุทธ์และเทคนิคต่างๆ ที่ผู้ไม่หวังดีใช้ในการโจมตีทางไซเบอร์ โดยอ้างอิงจากเหตุการณ์ที่เกิดขึ้นจริง เพื่อให้ฝ่ายป้องกันสามารถเข้าใจและรับมือกับภัยคุกคามได้ดียิ่งขึ้น

Tactic	Technique ID	Technique Name
Initial Access	T1190	Exploit Public-Facing Application
Persistence	T1505.003	Server Software Component: Web Shell
Defense Evasion	T1036	Masquerading
	T1027	Obfuscated Files or Information
Command and Control	T1071.001	Application Layer Protocol: Web Protocols
Execution	T1059.003	Command and Scripting Interpreter
Discovery	T1082	System Information Discovery
	Discovery	File and Directory Discovery
Impact	T1496	Resource Hijacking
	T1485	Data Destruction
	T1491	Defacement
	T1565.001	Data Manipulation: Stored Data Manipulation



Indicator of Compromise (IOCs)

Indicators of Compromise (IOCs) คือ ร่องรอยหรือหลักฐานทางดิจิทัลที่บ่งชี้ว่าระบบหรือเครือข่ายอาจถูกบุกรุกโดยผู้ไม่หวังดี ซึ่งทาง สกมช. ได้มีการแบ่งปันข้อมูล IOCs เหล่านี้ผ่านทางแพลตฟอร์ม MISP (Malware Information Sharing Platform) เพื่อเสริมสร้างความมั่นคงปลอดภัยไซเบอร์เรียบร้อยแล้ว โดยมีร่องรอยที่สามารถตรวจสอบได้ดังนี้

ร่องรอยที่สามารถตรวจสอบได้:

MD5

82a8bae3348be743e657ceb2cdb78d00

SHA-1

e24b6f294d10e8dc83ce8c4e471626bc1299cc67

SHA-256

5c32e55a6680b9f53d03e65793be4c292b80727fe4458ca3e612c535d1b3f36e



แนวทางการเฝ้าระวัง ป้องกัน และรับมือ

การเฝ้าระวัง (Monitoring)

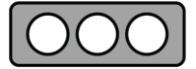
- ตรวจสอบความเปลี่ยนแปลงของไฟล์ : ติดตั้งระบบหรือเปิดใช้งานฟังก์ชันเพื่อตรวจสอบการสร้างไฟล์ใหม่ หรือการแก้ไขไฟล์ในโพลเดอร์สำคัญของ Web Application โดยเฉพาะโพลเดอร์ที่เปิดให้อัปโหลดไฟล์ได้
- เฝ้าระวังการเรียกใช้งานไฟล์สคริปต์ด้วย HTTP Method: POST ที่มีความถี่สูงผิดปกติ หรือมาจาก IP Address ที่ไม่คุ้นเคย
- เฝ้าระวังการเชื่อมต่อเครือข่าย (Network Monitoring): ตรวจสอบ Traffic ขาออกจาก Web Server ว่ามีการพยายามเชื่อมต่อไปยังพอร์ตแปลกปลอม หรือ IP ปลายทางที่มีประวัติเป็น Malicious (C2 Server) หรือไม่

การป้องกัน (Prevention)

- อัปเดตระบบ: ดำเนินการอัปเดตระบบปฏิบัติการ และซอฟต์แวร์ CMS ให้เป็นเวอร์ชันล่าสุด เพื่อปิดช่องโหว่ที่เปิดโอกาสให้ผู้โจมตีเจาะระบบเข้ามาได้
- ตรวจสอบความปลอดภัยของการอัปโหลดไฟล์: ตรวจสอบไฟล์ที่อัปโหลดอย่าง เพื่อป้องกันเทคนิคการปลอมแปลง และปิดการรันสคริปต์ในโพลเดอร์ Upload
- ติดตั้ง Web Application Firewall (WAF): เพื่อช่วยกรอง Traffic อันตรายและบล็อกรูปแบบการโจมตีก่อนที่จะเข้าถึงตัว Server

การรับมือ (Response)

- แยกอุปกรณ์ที่ติดเชื้อ : หากตรวจพบการบุกรุกหรือการทำงานของ Webshell ให้รีบตัดการเชื่อมต่อเครื่อง Server นั้นออกจากเครือข่ายภายนอกทันที เพื่อป้องกันการส่งการระยะไกล (C2) หรือการใช้เครื่องเป็นฐานโจมตีต่อไปยังเครื่องอื่น (Lateral Movement)
- เก็บหลักฐานทางดิจิทัล: รักษาสภาพของเครื่องที่ติดเชื้อไว้เพื่อการวิเคราะห์หาสาเหตุและสืบสวน (Digital Forensics) เก็บสำรอง Log Files และตัวอย่างไฟล์ Webshell ที่พบไว้เพื่อวิเคราะห์หาวิธีการเจาะระบบ (Initial Access) และเตรียมป้องกันการถูกโจมตีซ้ำในรูปแบบเดิม
- กำจัดภัยคุกคาม : ลบไฟล์ Webshell หลักและค้นหาไฟล์ Backdoor ที่ถูกฝังไว้ทั้งหมด โดยใช้ข้อมูล IOCs พร้อมทั้งตรวจสอบ Scheduled Task (Cron Jobs) ว่ามีการฝังคำสั่งให้ดาวน์โหลด Webshell กลับมาใหม่หรือไม่



- กู้คืนระบบ: กู้คืนระบบจาก Backup ที่ปลอดภัยหลังจากได้รับการยืนยันว่าได้ทำการอัปเดตความปลอดภัยและแก้ไขช่องโหว่ต่าง ๆ
- รีเซ็ตรหัสผ่าน: เปลี่ยนรหัสผ่านของผู้ดูแลระบบ, รหัสผ่านฐานข้อมูล, FTP, และ SSH ทั้งหมดทันที เนื่องจากมีความเสี่ยงสูงที่รหัสผ่านชุดเดิมจะถูกขโมยผ่าน Webshell ไปแล้ว
- รายงานเหตุการณ์: แจ้งเหตุการณ์ไปยังหน่วยงานที่เกี่ยวข้องภายในองค์กรและหน่วยงานด้านความมั่นคงปลอดภัยไซเบอร์



แบบประเมินรายงานข่าวกรองไซเบอร์

<https://dg.th/nsexlfob51>

จัดทำโดย

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน

ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ

โทร: 02 114 3531 อีเมล: cti_misp@ncsa.or.th